ENTERPRISE DATA GOVERNANCE FRAMEWORK DEVELOPMENT & ROADMAP FOR E-COMMERCE PLATFORM TRANSFORMATION

DATA GOVERNANCE POLICY

Document status: Proposed design for an illustrative e-commerce transformation case study. Organizational roles, thresholds, SLAs, retention periods, and regulatory interpretations require validation before production adoption.

DOCUMENT CONTROL

Field	Proposed Value
Document owner	Chief Data Officer (CDO) / Data Governance Office (DGO)
Policy owner	Enterprise Data Governance Lead / designated executive
Approver	Data Governance Council and authorized executive
Applies to	Employees, contractors, business units, systems, and third parties handling in-scope enterprise data, subject to contracts and law
Version	2.0
Review cycle	At least annually and upon material legal, business, security, or technology change
Status	Proposed policy; not effective until formally approved

1. PURPOSE

This policy establishes mandatory enterprise requirements for governing data as a business asset across the e-commerce lifecycle. It aims to ensure data is appropriately owned, defined, fit for purpose, protected, traceable, retained, and used in ways that support business operations, customer trust, analytics, and applicable obligations.

2. SCOPE AND APPLICABILITY

- **Business domains**: Customer; Product/Catalog; Order, Payment & Transaction; Vendor/Supplier.
- **Functions**: Marketing, Merchandising, Customer Service, Operations, Finance, Payments, Supply Chain/Procurement, Data/Analytics, IT, Security, Privacy, Legal, and Risk/Compliance.
- **Systems**: web/mobile applications, CRM, catalog/PIM, order management, payment and logistics integrations, ERP, operational databases, data lake/lakehouse, warehouse, BI/ML platforms, logs, exports, backups, and third-party services.

- **Data** in scope includes personal data, business-sensitive data, master/reference data, transaction records, derived attributes, reports, models, data products, and relevant third-party data.
- Where local law, regulation, contract, or a stricter approved security/privacy policy imposes a stronger requirement, the stronger requirement prevails.

3. POLICY PRINCIPLES

1. Data is an enterprise asset with named business accountability.
2. Data must have a defined purpose, approved use, and fit-for-purpose quality controls.
3. Data quality is managed proactively at source and across critical transformations.
4. Privacy, security, and compliance are designed into collection, use, sharing, storage, and deletion.
5. Data must be discoverable and interpretable through managed metadata, glossary terms, and lineage.
6. Access is granted on least privilege, need-to-know, and approved purpose.
7. Retention and deletion follow an approved schedule, legal holds, and applicable obligations.
8. Material data risks, incidents, exceptions, and remediation must be recorded and escalated.

4. GOVERNANCE ROLES AND ACCOUNTABILITY

Role	Mandatory Responsibilities
Data Governance Council	Approve enterprise policy and standards; resolve cross-domain conflicts; review material risks, exceptions, and KPI performance.
Data Governance Lead	Maintain policy/standards, control register, decision log, training, reporting, and review process.
Data Owner	Approve domain definitions, CDEs, quality rules/targets, permitted business uses, access purpose, and remediation priorities.
Data Steward	Maintain definitions, metadata, classification records, quality monitoring, issue tracking, and evidence of remediation.
Data Custodian / System Owner	Implement technical controls for access, security, logging, validation, lineage, backup, retention, and deletion.
Security, Privacy, Legal, Risk/Compliance	Set or advise on relevant controls and obligations; assess risks and incidents within their mandates.
All data users	Use data only for authorized purposes, protect it from inappropriate disclosure, report suspected issues, and follow handling requirements.

RACI Overview

R = Responsible for execution; A = Accountable for the outcome/decision; C = Consulted; I = Informed. Each activity should have one clearly identified A. Security, Privacy, Legal, Architecture, and Audit may have additional control or review obligations not fully represented in this simplified matrix.

Activity	Council	Governance Lead	Data Owner	Steward	Custodian / IT	Control Functions
Approve enterprise policy	A	R	C	I	C	C
Approve domain definitions/CDEs	I (escalation)	C	A	R	C	C where relevant
Define and approve DQ rules/targets	I	C	A	R	C	C where relevant
Monitor DQ and manage issues	I (material issues)	C	A	R	R for technical fix	C
Approve business access purpose	I	I	A	C	R for provisioning	C/approval per security policy
Implement technical access/security controls	I	C	C	I	R	A/R for security standards as applicable
Maintain catalog, glossary and lineage	I	A for framework	A for domain content	R	R for technical metadata	C
Approve high-risk policy exception	A or delegated executive	R for workflow	C/A within delegated authority	I	C	C/A for control sign-off
Resolve cross-domain definition conflict	A	R to coordinate	C	C	C	C
Independent control assurance	I	C	C	I	C	Internal Audit: A/R for audit work

RACI refinement: the original matrix treated the Governance Council as informed on many operational activities and used 'Policy Approval: Owner=R, Council=A'. The revised approach retains Council accountability for enterprise policy approval, while domain Owners are accountable for domain-level decisions. Access approval should

5. DATA OWNERSHIP, DEFINITIONS AND CRITICAL DATA

- Every critical data asset and Critical Data Element (CDE) must have a named Data Owner and designated Steward or equivalent operational contact.
- The Owner must approve business definitions, source-of-record decisions, criticality, quality targets, and permitted business use.
- CDEs must be identified based on customer, revenue, payment, fraud/risk, regulatory/reporting, and operational impact.
- Shared metrics and terms must be defined in the enterprise business glossary, including calculation logic, scope, exclusions, and effective date.
- Changes to definitions, source systems, schemas, or business rules must follow change management and include downstream impact assessment.

6. DATA CLASSIFICATION AND HANDLING

Class	Illustrative Examples	Minimum Handling Expectations
Public	Approved public product descriptions, public prices, published help content.	Approved for public release; protect integrity; do not include non-public operational metadata.
Internal	Internal operating procedures, non-public aggregate operational reports.	Access for authorized workforce; controlled sharing; secure storage and transmission according to baseline controls.
Confidential	Commercial terms, margin/pricing strategy, non-public supplier information, sensitive business forecasts.	Need-to-know access; approved sharing; encryption in transit and at rest where supported by the security standard; logging for sensitive systems.
Restricted	Personal data, payment-related sensitive data, authentication secrets, highly sensitive identifiers or legally restricted data.	Strict purpose limitation and least privilege; approved access; encryption; masking/tokenization where appropriate; monitored access; controlled export and sharing.

Classification is determined by sensitivity, impact, contractual/legal requirements, and context—not by a single data field alone. Personal data is not automatically treated identically in every context; the Privacy function must determine applicable handling requirements. Payment card data, credentials, and secrets may be subject to additional specialist standards.

7. DATA QUALITY MANAGEMENT

7.1. Required dimensions

- Accuracy
- Completeness
- Validity
- Consistency
- Uniqueness
- Timeliness
- Referential integrity where applicable

7.2. Minimum requirements

- Critical datasets must have documented, approved quality rules, thresholds, monitoring frequency, responsible owner, and remediation process.
- Rules must specify calculation logic, numerator/denominator, exclusions, expected timing, and severity of failure.
- Automated validation should be implemented at source, ingestion, transformation, or consumption layers based on risk and technical feasibility.
- Material quality failures must be logged, triaged, assigned, resolved, validated, and closed with evidence.
- Quality scorecards must disclose coverage and limitations; aggregate scores must not obscure critical defects.

Domain / Element	Illustrative Rule	Proposed Threshold / Response
Customer / customer_id	Identifier is populated for records requiring persistent customer identity.	100% of applicable records; exceptions documented.
Customer / email	Email format is valid; duplicate handling follows approved identity-resolution rules.	Define uniqueness by account/use case; shared or changed emails require controlled exceptions.
Product / SKU	SKU is unique within the defined product namespace; required price and currency are valid before publication.	100% of published active products meet mandatory rules.
Order / order_id	Order identifier is unique and order state follows approved transition rules.	100% uniqueness; invalid transitions investigated.
Payment / payment_status	Status belongs to the approved status set and reconciles with payment-provider events.	Target based on reconciliation coverage; critical mismatches escalated.
Vendor / vendor_id	Supplier identifier is unique and required onboarding fields are present before activation.	100% of active vendors meet mandatory onboarding rules.

All thresholds above are proposed examples. Data Owners must validate them against business process, architecture, data volume, and risk before adoption.

8. METADATA, CATALOG AND LINEAGE

- Critical datasets and data products must be registered in the approved catalog or controlled inventory.
- Minimum metadata includes name, business definition, owner, steward/contact, source/system of record, classification, criticality, refresh frequency, quality rules/status, approved consumers, and retention category.
- Tier-1/critical datasets must have documented end-to-end lineage from source through material transformations to key reports, data products, or models, subject to approved exceptions.
- Technical and business lineage must be updated after material pipeline, schema, or semantic changes.
- Business glossary terms and metric definitions must be versioned, approved, and linked to relevant assets.

9. MASTER AND REFERENCE DATA MANAGEMENT

Scope:

- Customer
- Product
- Vendor

- Customer, Product, and Vendor master data must have documented authoritative sources, matching/merging rules, stewardship, and change history where relevant.
- Golden-record logic, survivorship rules, manual override permissions, and exception handling must be documented and approved by the Data Owner.
- Duplicate resolution and identity linking must be proportionate to risk and must not merge records solely on weak or unverified matching evidence.
- Reference data and status codes used across systems must be governed through versioned definitions and controlled change.

10. ACCESS, USE, SHARING AND SECURITY

- Access must be approved for a defined business purpose and provisioned using least privilege, need-to-know, and segregation-of-duties principles.
- RBAC is the baseline; ABAC or other contextual controls should be used where sensitivity, geography, purpose, or user context requires finer-grained restrictions.
- Privileged and sensitive-system access must use approved strong authentication, including MFA where required by the security standard.

- Sensitive data must be protected in transit and at rest according to the approved security standard; masking, tokenization, or de-identification must be applied where appropriate.
- Access to sensitive datasets and privileged roles must be reviewed at least quarterly as a proposed baseline; more frequent review may be required by risk.
- Exports, downloads, external transfers, API sharing, and third-party disclosures must use approved channels, documented purpose, appropriate contractual terms, and required security/privacy review.
- Production data must not be copied to development, testing, or personal environments unless explicitly authorized and protected; synthetic or appropriately de-identified data should be preferred.
- Data users must not bypass access controls, combine datasets to infer restricted information without approval, or use data for a materially different purpose without review.

11. PRIVACY AND RESPONSIBLE USE

- Personal data must be collected and processed for specified, legitimate purposes with an appropriate legal basis and transparent notices where required.
- Collect and retain only data reasonably necessary for the approved purpose; avoid collecting sensitive attributes without a documented need and appropriate approval.
- New or materially changed processing, profiling, personalization, AI/ML use, cross-border transfer, or third-party sharing must be assessed with Privacy/Legal/Security as applicable.
- Support applicable data subject rights and requests through a controlled workflow with identity verification, response tracking, and evidence.
- Do not use personal data for incompatible secondary purposes without the required assessment, notice, legal basis, and approval.
- Apply human oversight and documented risk assessment to high-impact automated decisions where applicable.

This policy is designed to support assessment against applicable Indonesian personal data protection and electronic-system requirements, including Law No. 27 of 2022 where applicable. GDPR principles may be used as a reference where relevant, but applicability and legal obligations must be confirmed by qualified Legal/Privacy personnel. This policy is not legal advice.

12. DATA LIFECYCLE, RETENTION, LEGAL HOLD AND DELETION

- Each data category must have an approved retention schedule based on business need, applicable law, contracts, dispute needs, payment/accounting obligations, and privacy principles.
- Retention periods must not be adopted as universal defaults without Legal/Compliance approval. The data owner must document purpose, start event, retention period, archival requirements, and deletion method.
- Legal hold, investigation, audit, or dispute requirements suspend routine deletion for the affected records until the hold is formally released.
- Deletion must cover applicable active systems, replicas, exports, and downstream datasets where feasible; backup copies must expire under documented backup schedules unless a hold or legal requirement applies.
- Where complete deletion from immutable backups is not technically feasible, access must remain restricted and data must expire under a documented schedule.

Deletion and anonymization must be recorded with scope, date, method, executor, and exception details where evidence is required.

Data category	Retention Design Requirement	Decision Owner
Order/transaction/financial records	Set period by applicable tax, accounting, payment, dispute, consumer, and contractual obligations.	Finance + Legal/Compliance + Data Owner
Customer account and profile data	Define by account status, purpose, consent/legal basis, inactivity, dispute, and applicable deletion obligations.	Customer/CRM Owner + Privacy/Legal
Security and application logs	Set risk-based retention, access controls, investigation needs, and legal requirements.	Security + System Owner
Marketing and consent records	Retain sufficient evidence of preferences/consent and changes for the approved purpose and legal requirements.	Marketing Owner + Privacy/Legal
Supplier/vendor records	Set by onboarding, contract, payment, audit, and legal requirements.	Procurement/Finance + Legal/Compliance

13. DATA INCIDENT AND ISSUE MANAGEMENT

13.1. Data quality and governance issues

1. Detect and record the issue, affected asset, evidence, business impact, severity, and time detected.
2. Assign a Steward or accountable operational owner and notify the Data Owner.
3. Contain or mitigate immediate business impact where needed.
4. Perform root-cause analysis and assign corrective/preventive actions.
5. Validate the fix with appropriate business and technical tests.
6. Close only when evidence is recorded; monitor recurrence and update rules or process controls.

13.2. Security and personal-data incidents

- Suspected unauthorized access, loss, disclosure, alteration, or unavailability of sensitive data must be reported immediately through the approved incident-response channel.
- Security incident response takes precedence for containment and investigation; notify Security, Privacy, Legal, system owners, and relevant executives according to the incident plan.
- Assess affected data, individuals, systems, geography, third parties, and legal/contractual notification obligations.
- Only authorized functions may determine external notification, regulator engagement, or customer communication.
- Record timeline, containment, decisions, notifications, root cause, corrective actions, and lessons learned.

Severity	Illustrative Data Issue Response Target	Resolution Target
Critical	Within 4 hours	Within 24 hours or an approved containment/remediation plan
High	Within 1 business day	Within 5 business days
Medium	Within 2 business days	Within 10 business days
Low	Within 5 business days	Within 30 business days

These targets apply to governance/data-quality workflow examples only. They do not replace security incident response times or legal notification deadlines.

14. THIRD-PARTY AND EXTERNAL DATA

- Before onboarding a data provider or service provider, assess data provenance, quality, permitted use, security/privacy posture, retention/deletion, subcontracting, location, and transfer restrictions.
- Contracts or approved terms must define purpose, access, permitted onward sharing, incident notification, return/deletion, audit/evidence rights where appropriate, and responsibilities.
- Third-party data must be classified, catalogued, assigned an internal Owner, and subject to quality validation before critical operational or analytical use.
- Material changes to provider, data fields, processing location, or use case require impact and risk review.

15. DATA ARCHITECTURE, CHANGE AND AI/ANALYTICS USE

- New or materially changed data pipelines, data products, BI metrics, integrations, and ML/AI use cases must assess data quality, lineage, access, classification, privacy, retention, and downstream impacts.
- Critical transformations must be version-controlled, testable, monitored, and traceable to source and rule definitions.
- Reports and metrics used for financial, regulatory, executive, or material customer decisions must have documented definitions, owners, refresh expectations, and validation controls.
- Model training data and derived features must have documented provenance, intended use, access controls, limitations, and retention requirements.
- Production changes must follow approved change management, testing, rollback, and communication procedures.

16. EXCEPTIONS, NON-COMPLIANCE AND ENFORCEMENT

- Policy exceptions must be documented with business justification, affected assets, risk assessment, compensating controls, accountable approver, remediation plan, and expiry date.
- The Data Owner may approve only exceptions within delegated authority. Exceptions involving material security/privacy/legal risk require relevant control-function review and may require Council or executive approval.
- Exceptions must be time-bound, tracked, reviewed before expiry, and closed with evidence. Indefinite exceptions are not permitted without formal policy amendment.
- Suspected non-compliance must be reported and investigated through appropriate governance, HR, Security, Privacy, Legal, or Compliance processes.
- Corrective actions may include access restriction, remediation, retraining, process changes, or disciplinary/contractual measures in accordance with applicable policies and law.

17. GOVERNANCE KPIs AND REPORTING

KPI	Definition	Proposed Steady-State Target	Reporting Owner / Frequency
CDE Data Quality Pass Rate	Applicable CDE records passing approved rules / tested CDE records × 100.	≥95%, with critical rules separately monitored.	Domain Owner; monthly
Critical Asset Owner Coverage	Critical assets with named Owner / total critical assets × 100.	100%.	Governance Lead; monthly
Metadata Completeness	Critical assets meeting mandatory metadata requirements / total critical assets × 100.	≥98%.	Stewards/Governance Lead; monthly
Tier-1 Lineage Coverage	Tier-1 assets with documented end-to-end lineage / total Tier-1 assets × 100.	100% target, subject to approved scope.	Architecture/Data Engineering; monthly
Issue SLA Compliance	Issues resolved within applicable SLA / issues due for resolution × 100.	≥95%.	Domain Owners; monthly
Privileged Access Review Completion	Required reviews completed on time / reviews due × 100.	100%.	Security/System Owners; quarterly
Data Incident Trend	Count, severity, business impact, recurrence and root-cause categories.	Establish baseline, then demonstrate sustained improvement.	Governance Council; quarterly

KPI definitions, source systems, denominators, exclusions, measurement periods, and target dates must be approved and documented. A target is not an achieved result until measured evidence supports the claim.

18. AUDIT, EVIDENCE AND CONTROL ASSURANCE

- Control owners must retain evidence of execution, review, exceptions, and remediation according to the approved evidence-retention schedule.
- Evidence may include access approvals/reviews, quality results, issue tickets, lineage records, deletion logs, training records, exception approvals, and meeting decisions.
- Governance controls should be periodically assessed for design and operating effectiveness using risk-based assurance.
- Audit findings must have accountable owners, due dates, risk ratings, and tracked remediation; overdue high-risk findings must be escalated.

19. POLICY REVIEW, APPROVAL AND COMMUNICATION

- The policy owner must review this policy at least annually and after material legal, business, organizational, platform, or risk changes.
- Material changes require documented review by affected business owners and relevant Security, Privacy, Legal, Risk/Compliance, and Technology functions.
- The approved version, effective date, approver, revision history, and related standards must be published in a controlled repository.
- Affected personnel and third parties must be informed of relevant requirements and complete role-based awareness or training where required.

Appendix A. Minimum Data Asset Record

- Asset name and unique identifier; business definition; domain; Owner; Steward; technical Custodian.
- Source system/system of record; criticality/Tier; classification; purpose and permitted consumers.
- CDEs, quality rules, thresholds, latest quality status, open issues, and remediation contacts.
- Lineage, refresh frequency, dependencies, data products/reports/models using the asset.
- Retention category, deletion requirements, sharing restrictions, legal holds, and applicable control references.

Appendix B. Approval Checklist Before Policy Becomes Effective

- Confirm applicable laws, regulations, contractual requirements, and regulatory scope with Legal/Privacy/Compliance.
- Approve classification and technical handling standards with Information Security.
- Approve domain Owners, Stewards, CDE inventory, and authoritative sources.
- Validate retention periods and deletion implementation with Legal, Finance, Privacy, Records Management, and system owners.
- Approve quality thresholds, severity criteria, issue SLAs, access-review frequency, exception authority, and evidence retention.
- Confirm operational tooling, workflows, training, exception register, and reporting cadence.
- Obtain formal approval, publish controlled version, communicate effective date, and track adoption.